

Grille d'évaluation de l'audit

Projet final · Auditer l'application de réservation



Catégories OWASP Top 10 2025

Dans l'édition 2025 du Top 10 de l'OWASP, un constat se range dans la catégorie qui décrit sa cause principale.

- ◆ A01 : Broken Access Control (contrôle d'accès défaillant) : accès à l'objet ou à la fonction d'un autre sans droit, y compris la requête émise par le serveur vers une cible choisie par le client (SSRF, rattachée à A01 dans l'édition 2025).
- ◆ A02 : Security Misconfiguration (mauvaise configuration de sécurité) : réglage par défaut, protocole ou en-tête faible, fichier ou page de diagnostic exposé.
- ◆ A03 : Software Supply Chain Failures (défaillances de la chaîne d'approvisionnement logicielle) : composant tiers vulnérable, compromis ou non mis à jour.
- ◆ A04 : Cryptographic Failures (défaillances cryptographiques) : chiffrement absent ou faible, données sensibles mal protégées en transit ou au repos.
- ◆ A05 : Injection : une donnée non fiable est interprétée comme du code ou du contenu (SQL, commande, HTML ou script, donc aussi le XSS).
- ◆ A06 : Insecure Design (conception non sécurisée) : une règle de sécurité manque dès la conception, ce n'est pas seulement un bogue de code.
- ◆ A07 : Authentication Failures (défaillances d'authentification) : identité mal vérifiée, mot de passe, session ou secret de signature mal protégé.
- ◆ A08 : Software or Data Integrity Failures (défaillances d'intégrité des logiciels ou des données) : code, mise à jour ou donnée acceptés sans contrôle d'intégrité.
- ◆ A09 : Security Logging and Alerting Failures (défaillances de journalisation et d'alerte) : événement de sécurité non journalisé ou sans alerte.
- ◆ A10 : Mishandling of Exceptional Conditions (mauvaise gestion des conditions exceptionnelles) : erreur ou cas limite mal géré.



Certitude pour la priorité

- ◆ confirmée = 4 : preuve directe et corroboration indépendante
- ◆ démontrée = 3 : revue de code ou configuration reproductible
- ◆ plausible = 2 : hypothèse étayée par une seule source
- ◆ scanner = 1 : signal seul, pas encore confirmé



Priorité

Priorité = note CVSS de base × criticité de l'actif × certitude.

Criticité des actifs : 1 faible, 2 utile, 3 importante, 4 critique.



CVSS v3.1

MÉTRIQUE	VALEURS
AV	N 0,85; A 0,62; L 0,55; P 0,2
AC	L 0,77; H 0,44
PR	portée inchangée (S:U) : N 0,85; L 0,62; H 0,27. Portée modifiée (S:C) : N 0,85; L 0,68; H 0,5
UI	N 0,85; R 0,62
C, I, A	H 0,56; L 0,22; N 0

- ◆ $ISS = 1 - (1 - C) \times (1 - I) \times (1 - A)$
- ◆ Impact si S:U = $6,42 \times ISS$
- ◆ Impact si S:C = $7,52 \times (ISS - 0,029) - 3,25 \times (ISS - 0,02)^{15}$
- ◆ Exploitabilité = $8,22 \times AV \times AC \times PR \times UI$
- ◆ Si Impact ≤ 0 , la note vaut 0
- ◆ Si S:U : note = Arrondi_sup(min(Impact + Exploitabilité, 10))
- ◆ Si S:C : note = Arrondi_sup(min($1,08 \times (Impact + Exploitabilité)$, 10))
- ◆ Arrondi_sup : le plus petit nombre à une décimale supérieur ou égal à la valeur.

QUALIFICATION	NOTE
Aucune	0,0
Faible	0,1 à 3,9
Moyenne	4,0 à 6,9
Élevée	7,0 à 8,9
Critique	9,0 à 10,0



Fait et hypothèse

- ◆ Un fait est visible dans un fichier, à une heure, un endroit ou une ligne précise.
- ◆ Une hypothèse propose une explication possible qui doit être confirmée par une deuxième preuve.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite.